Fiche de défense : VETO

Secure Horizons, track 1 « Fintech Security: Guardians of Value ». État du dépôt au 11 octobre 2026. Mesures du détecteur et cas manqués : fiche-defense-mesures.md. Rapport trimestriel historique : pitch-chiffres.pdf.

Scénario de menace

Facture piégée, rejeu et clé volée : le coffre borne montants, références et bénéficiaires admis. Le client signataire est un bouchon déterministe ; la référence inconnue est fixée par le script. Aucun LLM n'est trompé dans ce parcours. Le coffre ne vérifie pas la vérité d'une facture admise.

Fonctions NIST CSF 2.0 couvertes

Fonction	Ce que fait le projet	Où
Govern (`GV.RR`)	Cinq rôles séparés ; la réponse automatique bloque sans déplacer de fonds	`src/ArgentVault.sol`, `playbook.md`
Identify (`ID.AM`)	Registre des agents et mandats ; jeton court à la porte	`src/ArgentVault.sol`, `gateway/src/tokens.ts`
Protect (`PR.AA`, `PR.DS`)	Émetteurs admis du L1 ; signature EIP-712 ; anti-rejeu ; validation humaine au-dessus du seuil	`infra/l1/`, `docs-jury/preuves/scene-aws.md`
Detect (`DE.CM`, `DE.AE`)	Règles à la porte ; refus du contrat observés ; comité LLM séparé	`gateway/src/detector.ts`, `docs-jury/verificateurs-llm.md`
Respond (`RS.MA`, `RS.MI`, `RS.CO`)	Quarantaine, pause de l'agent, alerte, rapport d'incident prérempli, journal chaîné vérifiable par script	`response/src/engine.ts`, `playbook.md`
Recover (`RC.RP`)	Partiel : reprise humaine journalisée, aucun plan au-delà	`response/`

Techniques et risques visés

Référentiel	Éléments visés
MITRE ATLAS	AML.T0051 LLM Prompt Injection : .001 Indirect (la facture piégée), .000 Direct. AML.T0053 AI Agent Tool Invocation
MITRE ATT&CK	T1657 Financial Theft, T1565.001 Stored Data Manipulation, T1684.001 Social Engineering: Impersonation
OWASP LLM 2025	LLM01 Prompt Injection, LLM06 Excessive Agency, LLM05 Improper Output Handling
OWASP Agentic 2026	ASI01 Agent Goal Hijack, ASI02 Tool Misuse, ASI03 Identity & Privilege Abuse, ASI07 Insecure Inter-Agent Communication, ASI09 Human-Agent Trust Exploitation
OWASP Smart Contract 2026	SC01 Access Control, SC02 Business Logic, SC05 Lack of Input Validation, SC06 Unchecked External Calls, SC08 Reentrancy : revue interne, `docs-jury/rapport-securite.md`

Métriques de détection et de réponse (barème)

Métrique	Valeur	Conditions et source
Détection (rappel)	50 sur 100 (50 %)	100 attaques / 100 légitimes synthétiques ; `docs/mesures/bench-test.json`
Précision des blocages	50 / (50 + 4) = 92,6 %	Même jeu équilibré ; dépend de la fréquence des attaques
Faux positifs	4 sur 100 (4 %)	Demandes légitimes bloquées ; même jeu
Porte : arrivée → détection	226 ms	L1 AWS, scène 3 ; 1 incident, `docs/mesures/delais.json`
Porte : détection → réponse	Pause +24 ms ; alerte +32 ms	Hors chaîne, alerte affichée ; même incident
Contrat : arrivée → détection	Environ 1,9 s	L1 AWS, scène 4 ; 1 incident, horodatage du bloc ; `poc.md`
Contrat : détection → réponse	Pause +6,474 s ; alerte +6,482 s	À partir du bloc, indexeur compris ; hors chaîne ; `docs/mesures/delais.json`
Confinement des scènes	0 sortie de fonds sur 4 attaques	2 refus du contrat après passage de la porte ; anvil puis L1 AWS, `docs/mesures/demo.json`

Simulation reproductible séparée. 500 attaques, dix familles, coffre en mémoire : nominal, 100 blocs filtre + 400 refus coffre ; filtre aveugle, 450 refus + 50 paiements aux bons montant et bénéficiaire. Zéro unité détournée, zéro doublon. Ce run ne reproduit pas le trimestre historique. **Comité séparé :** médiane rapportée 39,8 s sur 16 demandes, trois Haiku, rapport. Preuves initiales : Haiku / Pixtral / Sonnet. Aucun vote ne pilote le coffre.

Limites connues

- Rapport trimestriel historique : simulation sur coffre en mémoire, volumes choisis. Script original et journaux bruts absents ; résultats non rejouables ici, aucun taux de fraude réel mesuré.
- Jeu synthétique écrit par un modèle, étiquettes non relues, attaques et légitimes à parts égales. En production les faux positifs pèseraient davantage. Rattrapage du contrat sur ces 100 attaques non mesuré. Délais : un incident par chemin, pas une distribution.
- Le contrat ne vérifie pas la vérité d'une facture : une fausse dette inscrite par le rôle d'admission serait payée. Un propriétaire ou un administrateur du L1 compromis sort du modèle.
- Simulation interne : la protection suppose le refus humain de 19 fausses factures ; leur approbation peut porter la perte à 1 016 807 €.
- Seuls les fonds détenus par le contrat sont protégés. Par défaut (`VAULT_MODE=fake`), la démo locale tourne sur un faux coffre.
- La pause d'un agent est appliquée hors chaîne, par la porte et par le relais. Le contrat sait la poser (`pauseAgent`), aucun service ne l'appelle.
- L'alerte est affichée et journalisée, elle n'est envoyée à personne. La décision humaine est déclarée, pas authentifiée.
- L1 de test à un seul validateur, Fuji non testé, fonds de test sans valeur, revue de sécurité interne sans audit indépendant.